

Towards More Secure Interactions: Understanding User Experience and Behaviour in the NFT Domain

Wei Chen

wei.chen-10@student.uts.edu.au
University of Technology Sydney
Sydney, NSW, Australia

ABSTRACT

This study investigates the human errors that enable hackers to exploit and carry out social engineering attacks on the non-fungible token (NFT) ecosystem. The aim is to improve the design of decentralized applications that use NFTs to help non-technical users follow security best practices and address remaining user-side vulnerabilities. The study methods included a survey examining participants' expertise regarding NFTs and cybersecurity, a remote security usability study investigating the pain points and common security best practices and a follow-up interview to examine participants' experience with a crypto wallet configuration. The results show how human cognitive bias affects users' decision to be cautious, users' difficulty with security methods, and improvements to lessen users' cognitive load. As NFTs expand beyond the cryptocurrency circle, multiple scams and thefts arise due to late adopters not knowing the security best practices. Therefore, increasing the public's NFT security awareness is key to mitigating potential threats.

CCS CONCEPTS

• Security and privacy → Usability in security and privacy; • Human-centered computing → Usability testing; Heuristic evaluations.

KEYWORDS

Non-fungible tokens (NFTs), Social engineering

ACM Reference Format:

Wei Chen. 2024. Towards More Secure Interactions: Understanding User Experience and Behaviour in the NFT Domain. In *Extended Abstracts of the CHI Conference on Human Factors in Computing Systems (CHI EA '24)*, May 11–16, 2024, Honolulu, HI, USA. ACM, New York, NY, USA, 10 pages. <https://doi.org/10.1145/3613905.3650744>

1 INTRODUCTION

As non-fungible tokens (NFTs) have recently begun to expand their market, the marketplace saw an increase in crypto-curious late adopters with zero technical background. Multiple NFT frauds and social engineering attacks have been reported on the news, often due to not enabling security methods implemented in the system and following security best practices. Common system security

challenges from these attacks include intellectual property rights, cybersecurity and privacy issues. Many decentralized applications implemented security measures to battle these challenges, such as MetaMask's phishing detection [2] or the ability to adjust spending limits [5]. However, with late adopters joining the game, they brought human vulnerabilities into the NFT marketplace, rendering these security measures useless due to a lack of expertise. This wave of new users often does not take precautions or misconfigure security settings. NFT marketplaces mainly focus on identifying and fixing technical vulnerabilities but do not deal with human vulnerabilities. Due to being a relatively new industry, the NFT ecosystem is mainly dominated by developers and opportunists with backgrounds in blockchain and cryptocurrency. Thus, NFT developers did not consider the usability factor for late adopters. Many beginners learn about blockchain and NFT through news and social media. They often mention the opportunities of NFT trading and how it provides total transparency and anonymity when doing transactions. However, new users are rarely exposed to blockchain jargon and technical aspects, such as setting up their accounts and configuring security measures [17]. In addition, new users are often the main target of social engineering and phishing attacks because they are new to the market and often behave based on their cognitive bias and lack of awareness. Human errors like cognitive biases, or "human hardware vulnerabilities," are aspects developers often overlook when patching up technical vulnerabilities and attack vectors that external actors exploit [12]. Cognitive bias is a systematic error in thinking when people process information around them, which affects their decision-making and judgment. Bias occurs when the human brain tries to simplify information and helps people make quick decisions based on previous knowledge [12]. This behavior could result in a social engineering attack. Social engineering is when malicious actors exploit emotional appeals like fear, pity, and excitement to trick the victim into exposing their private keys or convince them to click malicious links and download malware files on social media [13]. Some social engineering attack vectors include [12]

- Confederate: Creating a false scenario that could force victims to reveal sensitive information.
- Online fraud: Hiding behind a fake identity and communicating with the victim. The process involves lowering the victim's guard to obtain the necessary information.
- Bait: Pretending to be a well-known NFT artist or content creator to trick the victim into buying the NFT to execute the fraud.

The lack of awareness about NFTs is the factor that leads to human errors. As mentioned above, many users believe blockchain provides anonymous transactions but, in actuality, only provides

Permission to make digital or hard copies of part or all of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for third-party components of this work must be honored. For all other uses, contact the owner/author(s).
CHI EA '24, May 11–16, 2024, Honolulu, HI, USA
© 2024 Copyright held by the owner/author(s).
ACM ISBN 979-8-4007-0331-7/24/05
<https://doi.org/10.1145/3613905.3650744>

pseudo-anonymity. This belief would prevent users from taking precautions when making transactions and exposing their identities. Another factor users do not realize is the two-factor authentication (2FA) option. Many NFT users are unaware of or have not enabled additional security measures like 2FA because many NFT marketplaces have not made the option apparent to users [6]. Like other financial sectors, NFT marketplaces like Nifty and Sorare provide 2FA but do not enable it as default and leave it as an option for users to choose. 2FA remains optional until the infamous Nifty Gateway hack compromises a small group of accounts [6]. The initial assessment then informs that all impacted accounts did not use 2FA [6]. Like 2FA, many users are unaware they can adjust their spending limit on their digital wallet due to believing that the setting is fixed or was not introduced during the onboarding process [5]. The NFT marketplaces allow two types of digital wallets: hot and cold. Hot wallets are online and website-based, while cold wallets are offline and based on hardware or paper [13]. Social engineering attacks often involve hot wallets [13] because they contain public and private keys and travel online, unlike cold wallets with enhanced security benefits enabled by their hardware components [3]. Human errors like decision-based errors could occur in cybersecurity. Inaction like choosing not to utilize VPN or antivirus software or not balancing the funds between hot and cold wallets because of convenience could cost users a massive loss in the long run. Actions like these are rarely outlined in the onboarding process [17], and often, these best security practices can only be found on websites or blogs through self-research. This study investigated how much knowledge new users have about NFT security procedures and best practices and figured out security-related areas or processes users need help executing. The study proposes a new solution to address improvements and pain points regarding security procedures from interview and survey data. A user-centric design can commercialize NFT-related applications to a broader market and advance NFT research to transform the internet into a fully Web3 world.

2 METHOD

2.1 Study Setting and Participants

First, a user's security awareness survey was conducted online on Google Forms, and then a security usability evaluation with a follow-up interview was conducted online through Zoom, lasting 30 minutes. The demographics will consist of users with limited technical knowledge to test how much they know about NFT procedures and cybersecurity. Participants were recruited through various platforms, from online communities interested in NFT-related topics like Reddit and Facebook to survey distribution sites with selection criteria like SurveySwap. There were 38 respondents for the users' security awareness survey and five participants in the security usability evaluation and interview (ages between 18 and 65 years old).

2.2 Data Collection

The user's security awareness survey aims to understand how knowledgeable the sample size of non-technical NFT users is about NFT security. The Google Form included closed-ended and open-ended questions. At the end of the survey, it asked whether the user would be interested in participating in a security usability

test to improve NFT-related application UX/UI to guide users on executing proper security procedures. This survey aimed to identify common cybersecurity and NFT knowledge and narrow down the demographic of users who are interested in improving UX/UI that is security-oriented. The data focused on NFT security best practices, cognitive bias about NFT, and security threats/frauds in NFT communities. The NFT security best practices and threats were gathered from the QuickNode documentation [1]. The closed-ended questions focused on which NFT security-related topics are common knowledge among users and which need clarification. The follow-up open-ended questions covered why participants knew these topics and did not know the other and how to improve the delivery. For the security usability study, each participant would be given a list of tasks relating to security best practices and procedures. The task will be [16]:

- Download and Installation: Participants must safely download MetaMask from an official website.
- Create an account: Participants must create their account with a unique password.
- Verification: Participants must store their secret recovery phrases and re-enter for verification. Participants should verify whether their account exists through Etherscan.
- Secure: Participants then review the security configuration and determine which setting to enable.
- Fund: Participants must use a Sepolia testnet faucet to fund their wallets.
- Connect to NFT marketplace: Participants must locate an NFT marketplace and connect their wallet.

When conducting the remote testing, the moderator asked each participant to think aloud about their thought process when doing these tasks for further behavior analysis. The crypto wallet used in this experiment was MetaMask as one of the most popular cryptocurrency wallets [9]. The interview consisted of a mix of 15 open and closed-ended questions. The open-ended questions would be asked before and after the usability evaluation. The pre-usability study questions focused on participants' previous knowledge and expectations regarding smart wallets and their security procedures. The post-usability study questions covered participants' reactions, experiences and concerns regarding the security-related tasks. There were questions on whether the participants understood the security features and warning messages and thought about the guidance they received in helping them understand the security implementations.

2.3 Data Analysis

The survey data is modeled using a table to show the percentage of respondents who chose that option for each closed-ended question. The data presented which NFT security topics developers need to focus on delivering the concept to make it easier for users to understand and operate without much difficulty. The open-ended questions explained why certain NFT security best practices or frauds users are more aware of than others and how to improve user information delivery. In the security usability evaluation, participants' common security practices were interpreted using a security best practices checklist compiled from multiple sources [1][8][18] and presented in a table to show the number of participants that

performed certain practices for each task. The recorded interview provided more detailed information about participants' common knowledge of crypto wallets and their feelings regarding security measures after encountering them. The thematic analysis [11] from the interview identified common pain points and impressions among participants before and after using the crypto wallet and experiencing the NFT space for the first time. The analysis also gave insight into improvements participants want in the design to help them learn and understand NFT's security procedures and best practices. The prototyping involved low-fidelity (lo-fi) and high-fidelity (hi-fi) prototypes [10]. The lo-fi prototype will be in two iterations: a paper prototype and low-fidelity wireframes. The hi-fi prototype included all the details in the lo-fi wireframes with color schemes and added content and underwent a heuristic evaluation focusing on user security to see whether the proposed design has any design problems [14]. Specific questions related to the crypto wallet and security for each usability heuristic are used to evaluate the design. The scale of issue severity will be: (0) No usability problem at all, (1) Cosmetic, (2) Minor, (3) Major, and (4) Critical.

3 RESULTS

3.1 User's Security Awareness Survey

The survey was distributed to multiple online communities interested in NFT and NFT novices, the target age group between 18 and 65. There were 38 responses with demographics from around the world. Table 3 presents the number of responses for each closed-ended question on Appendices. In the open-ended questions, participants explained the reason behind their chosen answers. The participants were identified using their participant number next to their responses for each question.

3.1.1 Key Insights Regarding Some Misconceptions about NFT. Using a crypto wallet while other tabs are opened is safe:

- P2: "This is because the online crypto wallet has extra securities and is pass-warded."
- P3: "Other Tabs opened does not affect your activities on MetaMask."

SMS/Email authentication for NFT accounts is safe:

- P2: "This is to provide an extra layer of security."
- P3: "It allows only me to have access to my account, and hackers cannot easily access my account."

Storing a seed phrase in any digital device (E.g., Password manager app, cloud storage account, on your phone):

- P36: "Any place where it's not directly accessible yet easily accessible for myself."
- P32: "Just feels reliable."
- P31: "Might be safer."

3.1.2 Notable Knowledge Gap in NFT. About 65.8% of participants did not understand or were unsure about NFT providing total anonymity and complete transparency, many citing not having the knowledge or delving deeply into the security measures.

- P24: "I am not aware of the depths of the security measures."
- P22: "I trust NFT, but do not have the expertise to tell if it's 100% secure."

About 71.1% of participants did not know the different types of crypto wallets and knew that it is best to use both hot and cold wallets for safety and flexibility. However, 15.8% decided to use both wallet types. The key reasons are

- P38: "Some for long-term hold."
- P36: "Both have their benefits."
- P19: "Only assets that are frequently used are stored in the hot wallet."

About 50% of participants were unsure whether using 2-factor authentication with an NFT platform should be optional. Of the 28.9% of participants who disagree that 2FA is optional, many highlighted the importance of having an additional security layer.

- P1: "It is best to have 2FA in any circumstances, as 2FA adds a layer of security by ensuring that you yourself is in control of any changes (not easily changed without having a confirmation sent to a different device or platform owned by yourself)."
- P29: "In summary, while NFTs themselves are stored securely using blockchain encryption, the platforms and accounts used to manage NFTs can still be vulnerable to security threats. Implementing 2FA is highly advisable as an additional security measure to protect user accounts and ensure the safe management of valuable digital assets."

3.1.3 Common NFT Security Knowledge. About 44.7% of participants know they should always research well-known NFT projects on social media before investing. Here are some key insights.

- P3: "It's always important to DYOR in the cryptocurrency space before investing in any project."
- P6: "I try to play it safe every time it involves money exchange on the web."

Another best practice the majority knows is splitting and storing the seed phrase, a group of random words generated by the crypto wallet upon onboarding, in separate places. Some participants know this method would provide extra security. In contrast, others use their intuition and see splitting and storing the seed phrases as necessary even if they have not done it.

- P6: "This seems like the safer option."
- P2: "So in case there is an attack, you won't lose all"
- P10: "Just seems better, just in case. Like it is not recommended to keep credit card and pin code together in the wallet."

About the seed phrase storage, about 47.4% of participants said they would store it on paper, one of the most recommended storage places.

- P6: "I don't use crypto often. If I did, and I had large amounts of it, I'd probably use on paper only"
- P2: "With paper. I can securely save with my documents and certificates in a vault."
- P5: "Hardcopy is very important too"

3.2 Security Usability Evaluation

Five respondents participated in the security usability study, ranging in age between 18 and 60 and have 0 to 8 years of experience with crypto wallets. Table 4 shows the number of participants who followed the following best practices.

Table 1: Pain Points Identified from Security Usability Evaluation

Pain Points	Page	Detail
Technical Jargon	Security & Privacy	Only configured settings they understood and
	Advanced	left remain as defaults/turn off to be safe.
	Alerts	1 participant was skeptical about IP-related settings.
Influence of Previous Experience/ Cognitive Bias	Sign-Up	2 participants did not create a very strong password when signing up. 2 participants skipped watching the tutorial videos.
	Security & Privacy	Rarely check security features
	Advanced	
	Alerts	
	Connect to NFT Marketplace	Multiple participants did not hesitate to connect to OpenSea without doing any background check. No participants considered disconnecting their wallets from the NFT marketplace and logging out of their MetaMask account. Participants chose not to log out of their MetaMask wallet because they found it unnecessary and wanted it open to access later quickly.

3.3 Interviews

A summary of the critical themes from the interview transcripts is available in Table 2. From the pre-study interviews, one participant mentioned they had a background in crypto and felt fully confident in crypto wallets' level of security compared to the remaining participants who only heard about Bitcoin or knew someone who used a crypto wallet. Similar to the post-study interviews, another participant with a crypto background found most security processes straightforward. In contrast, the remaining participants struggled with understanding them when seeing them for the first time.

Table 5 shows the improvements to help avoid misconfiguration and enforce strict security measures until beginners are comfortable with the system.

4 DISCUSSION

4.1 Cognitive Bias from Survey Results

Not all experiences and knowledge can be applied to NFTs due to differences between Web2 and Web3 apps. One difference is that it is a best practice to use a crypto wallet as the only tab in the browser or have a dedicated browser for it [18]. Although security severity varies depending on use cases, social media and Google account tabs open on the same browser as MetaMask could provide a vector for malicious actors on those platforms to trace back to the user's wallet address and steal underlying data. As hackers become more advanced in their attack vectors, hidden malicious websites could lead to hacks from one tab to another and insert malicious code into a legitimate website to launch an affected script on the browser through Cross-Site Scripting (XSS) to steal sensitive information [4]. With 13.2% of participants agreeing that users can safely use an online crypto wallet with opened tabs and 73.7% are unsure, this result shows that NFT beginners do not encounter these risks from

Table 2: Key Points from Interviews

Key Points	Page	Detail
Lack of Information about Data Backup and Recovery	Settings	1 participant has no confidence in trying to back up and recover data. 1 participant mentioned that backup and data recovery are not the primary concerns. The other 2 participants stated that it is vital to backup and recover data, but they are unaware of how to do this. 1 participant found data backup and recovery essential but was not confident using the functionality on the first attempt. They believe that if they use MetaMask more often, they would feel confident backing up their data.
Believe crypto wallets behave like other Web2 apps	All	2 participants thought using a crypto wallet would be like e-wallets with a verification process using personal information and entering a passcode and OTP code. 1 participant thought a crypto wallet account is like a Robinhood trading account with a single sign-on. 1 participant skipped securing their wallet with a secret recovery phrase because they thought having a password was sufficient.
Not understanding NFT-specific security features	Security & Privacy	3 participants do not know about crypto wallet's security. The participant found all the security terms and settings technical when using them.
	Advanced	
	Alerts	

reading through their frequently used media for NFT. The misconception and lack of information regarding this risk lead users to display optimism bias [7], where they would carry a false optimistic notion that crypto wallets are fully secure and previous experience where they use other apps while having multiple tabs open without risk. Another misconception appears around SMS/Email authentication in the NFT space. 34.2% of participants agree that using SMS/Email authentication is safe, and 50% are unsure regarding the statement. Participants who agreed state that this authentication method provides an extra layer of security and prevents other unauthorized users aside from themselves from accessing their accounts. However, it is recommended that users avoid SMS/Email authentication and opt for app-based 2FA [1]. Only 15.8% of participants disagreed that using SMS/Email authentication is safe and knew that app-based is more secure. This result shows that many NFT users also lack knowledge regarding the type of 2FA available and display availability bias [7]. Availability bias is when the user makes a mental shortcut that relies on the information that comes first to their mind. Users often rely on their memory, experience or industry trends instead of thoroughly analyzing all the potential risks [7]. The result shows that NFT beginners instantly conclude that any 2FA is safe against external threats and unaware that malicious actors can compromise their SMS or Email accounts or intercept and read unencrypted text through a Man-in-the-Middle (MITM) attack to eavesdrop on a conversation [4]. Thus, NFT beginners need to know the appropriate security measures they should take, such as opting for app-based 2FA instead of SMS/Email authentication.

4.2 Security Usability Evaluation & Interviews

In the Secure step, many participants did not fully understand each setting's functionality due to the jargon used in the description. Thus, participants only adjust the configuration they understand, such as keeping "Show incoming transactions" and "Use Phishing Detection" measures in place. While MetaMask already enables necessary security measures on default, settings like "Participate in MetaMetrics" are optional because they are used for collecting data to improve user experience. However, when participants read the description for the feature out loud, which only states to participate in MetaMetrics to help make MetaMask better, participants decided to keep the configuration, thinking that it would improve MetaMask. Other security measures like spending limits, auto-lock timer and alert configurations were left untouched because most participants did not consider exploring the Advanced, Alerts and Experimental pages or did not understand the functionalities to make any adjustments. Although alert configurations are on by default, users need to understand that these security measures are available and their purposes rather than passively receiving the alert messages and closing them immediately without heeding the warnings. The Connecting to NFT Marketplace step only had 1 or 2 participants performing some security best practices. Most participants clicked on the OpenSea website, the first result when searching for NFT marketplaces. Not checking the website's legitimacy before connecting one's wallet could be due to the participant's habit and experience using previous applications. Although OpenSea is the largest and most well-known NFT marketplace, users must be careful in checking any project because OpenSea's openness allows listing low-quality or fraudulent NFTs. For the disconnect practice, 3 participants needed a step-by-step guide from the facilitator. This shows that many are unaware of the process and security benefits of disconnecting one's wallet after using it because it is uncommon in other electronic payment methods. There was also a lack of action for logging off from Metamask, possibly due to participants' habits and experiences or the preference for convenience over security. The post-usability interviews showed that all participants struggled to understand MetaMask's data backup and recovery feature. Participants are more willing to test the toggle security settings because the process is transparent, even if the description of each feature has jargon that beginners have difficulty understanding. Compared to the toggle security settings, MetaMask does not explicitly state how users could back their wallets under the Protect Your Wallet section and use the secret recovery phrase to import users' wallets. Information about MetaMask's data backup and recovery often can be found on the official FAQs or the community forum, which users need to self-explore. Backing up using a secret recovery phrase is uncommon in Web2 because Web3 applications are self-custody. Web2 apps have a centralized server that mainly stores and manages users' data. Users can constantly make multiple copies of their data and store it on a server like cloud storage, where they can recover it in its original state if the primary data is corrupted or confiscated. These servers own the data copies due to owning the users' accounts, but Web3 apps where only those who knew the private keys own the account [15]. This method means that users have full custody of their accounts because this crypto wallet gives them full custody of their keys instead of managing

them. Therefore, MetaMask does not store any data about users' wallets and only gives the secret recovery phrase once, and it cannot be changed or reset [15]. The interview results show that it is essential that MetaMask suggest resources users can check that explain the self-custodial model and how they must be responsible for their secret recovery phrase to back up and recover data.

5 CONCLUSION

The general population still lacks awareness of NFT best practices and cybersecurity threats due to limited guidance and less sophisticated UX/UI. The proposed prototype tackles the problems by increasing the transparency of security features, reducing the cognitive load and adding restrictions on sensitive configurations. Although the design increases the usability of security features and mitigates human errors, some user security aspects still need to be addressed when interacting with external applications, where threats most likely occur. Situations like users' behavior when encountering social engineering attacks or their security habits over time. Therefore, the whole NFT space needs to consider human errors when expanding beyond the crypto field, as most NFT hacks often occur not on the blockchain but from compromised credentials, phishing attacks and poor security hygiene.

ACKNOWLEDGMENTS

This research study was supervised by Dr Baki Kocaballi (University of Technology Sydney). He contributed to the conceptualisation, research study plan, ongoing monitoring of the project, and critical review of the paper.

REFERENCES

- [1] 2023. Common Security Flaws around NFT Projects & How to Protect Against Them. <https://www.quicknode.com/guides/web3-fundamentals-security/security/common-security-flaws-around-nft-projects-how-to-protect-against-them/>
- [2] 2023. "Deceptive site ahead" when trying to connect to a site. <https://support.metamask.io/hc/en-us/articles/4428045875483--Deceptive-site-ahead-when-trying-to-connect-to-a-site>
- [3] Tobi Opeyemi Amure. 2023. Hot Wallet vs. Cold Wallet. <https://www.investopedia.com/hot-wallet-vs-cold-wallet-7098461#:~:text=Hot%20and%20cold%20wallets%20are%20the%20primary%20means%20of%20storing,such%20as%20a%20USB%20stick>
- [4] Kurt Baker. 2023. 10 Most Common Types of Cyber Attacks. <https://www.crowdstrike.com/cybersecurity-101/cyberattacks/most-common-types-of-cyberattacks/>
- [5] Ong Bobby. 2021. Pro Tip for anyone using Metamask to interact with smart contracts - don't set unlimited spend limit when approving transactions.
- [6] Dipanjan Das, Priyanka Bose, Nicola Ruaro, Christopher Kruegel, and Giovanni Vigna. 2022. Understanding Security Issues in the NFT Ecosystem. , n/a pages. <http://ezproxy.lib.uts.edu.au/login?url=https://www.proquest.com/working-papers/understanding-security-issues-nft-ecosystem/docview/2598842637/se-2>
- [7] Steve Durbin. 2022. 10 Cognitive Biases That Can Derail Cybersecurity Programs. <https://www.securitymagazine.com/articles/96918-10-cognitive-biases-that-can-derail-cybersecurity-programs>
- [8] Alex Gomez. 2023. How to Keep MetaMask Secure in 2023 (Top Safety Tips). <https://cyberscrilla.com/how-to-keep-metamask-secure/>
- [9] Matt Hussey and Daniel Phillips. 2022. What is MetaMask? How to Use the Top Ethereum Wallet. <https://decrypt.co/resources/metamask>
- [10] Arun Kewat. 2021. NFT Planet: UX case study to create a exchange platform to trade in NFTs. <https://medium.muz.li/nft-planet-ux-case-study-to-create-a-exchange-platform-to-trade-in-nfts-6a034634de8b>
- [11] Kai-Ting Lin. 2022. *Cunning Cat, Naive Fox — Security or Convenience? — A MetaMask UX Redesign Case Study*. <https://bootcamp.uxdesign.cc/cunning-cat-naive-fox-security-or-convenience-a-metamask-ux-case-study-8291dc3be5a1>

- [12] Lunaray. 2022. Web3 anti-fraud security knowledge part 2–Cognitive Bias. <https://medium.com/coinmonks/web3-anti-fraud-security-knowledge-part-2-cognitive-bias-b28e4bd3704a>
- [13] Kshetri Nir. 2022. Scams, Frauds, and Crimes in the Nonfungible Token Market. , 60–64 pages. <https://doi.org/10.1109/MC.2022.3144763> ID: 1.
- [14] Paulo C. Realpe, Cesar A. Collazos, Julio Hurtado, and Antoni Granollers. 2016. A Set of Heuristics for Usable Security and User Authentication. In *Proceedings of the XVII International Conference on Human Computer Interaction (Salamanca, Spain) (Interacción '16)*. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/2998626.2998662>
- [15] Oliver Renwick. 2021. What's In A Self-Custody (Non-Custodial) Wallet, Anyway? <https://consensys.io/blog/whats-in-a-self-custody-non-custodial-wallet-anyway>
- [16] George Robertson and Kennedy Whitehead. 2019. Investigating the Usability Issues Non Crypto Savvy Users Encounter When Setting Up Desktop Wallets for Staking (D)PoS Cryptocurrency. <https://uxplanet.org/investigating-the-usability-issues-non-crypto-savvy-users-encounter-when-setting-up-desktop-948f6381c974>
- [17] Stan Sakharchuk. 2022. Challenges Faced When Developing NFT Marketplaces. <https://interexy.com/challenges-faced-when-developing-nft-marketplaces/>
- [18] Hitesh Sant. 2022. A Beginner's Guide To MetaMask: The Most Powerful Hot Ethereum Wallet. <https://geekflare.com/finance/beginners-guide-to-metamask/>

A RESULTS

Table 3: User's Security Awareness Survey Responses

Question	Option	Percentage (%)
Have you ever experienced any social engineering attacks (E.g., email phishing, pretexting, etc.)?	Yes, I have experienced some.	55.3
	No, I have always been careful.	26.3
	No, I have never encountered them.	18.4
Do you know how to tell if your account is hacked or infected?	Yes, I know what to look for to see if my account is hacked or infected.	76.3
	No, I do not know what to look for to see if my account is hacked or infected.	23.7
NFT provides total anonymity and complete transparency.	Agree.	10.5
	Disagree.	23.7
	Not sure.	65.8
Would you use a hot wallet, cold wallet or both?	Hot Wallet.	5.3
	Cold Wallet.	7.9
	Both.	15.8
	I don't know about these options.	71.1
2-factors authentication (2FA) is optional when using an NFT-related platform because NFT is encrypted.	Agree.	21.1
	Disagree.	28.9
	Not sure.	50
Before investing, do you always need to research well-known NFT projects/accounts on social media platforms like Twitter or Discord?	Unnecessary.	10.5
	Sometimes.	23.7
	Often.	21.1
	Always.	44.7
Users can safely use an online crypto wallet (e.g., MetaMask) when other tabs are open.	True.	13.2
	False.	13.2
	Not sure.	73.7
How many of these NFT-related frauds and attacks do you know?	Token Copies.	15.8
	Rug Pulls.	21.1
	Airdrops.	28.9
	Social Engineering.	42.1
	Phishing Scams.	73.7
	Plagiarized NFTs.	44.7
	Bidding Scams.	36.8
	Other: Social Media Scams.	2.6
	Other: None	7.8

Where do you mostly learn about these frauds and attacks?	NFT Marketplace website.	18.4
	NFT Wallet website.	10.5
	Social Media (Twitter, Discord, etc.).	71.1
	NFT-related Blog (Medium, etc.).	31.6
	Other: News.	5.3
	Other: Hearsay.	2.6
	Other: Media.	2.6
	Other: From my previous employer (financial institution).	2.6
	Other: Cybersecurity classes and courses.	2.6
	Other: None.	2.6
How would you store a seed phrase (a group of random words generated by your crypto wallet when you first set it up)?	Password manager app.	39.5
	On your phone.	18.4
	On paper.	47.4
	Cloud storage account.	18.4
	Flash drives.	7.9
	Screenshots.	13.2
	Other: I don't know.	5.3
	Other: iPhone's Note.	2.6
	Other: By heart, mostly.	2.6
Splitting your seed phrase and storing them in separate places is recommended.	Other: The place where I put all my passwords.	2.6
	Agree.	63.2
	Disagree.	2.6
NFT wallet automatically sets a reasonable spending limit for every new user that just joined.	Not sure.	34.2
	True.	7.9
	False.	18.4
Are you aware of these recommended actions when your NFT account is compromised?	Not sure.	73.7
	Use Etherscan to check transactions.	10.5
	Disconnect any wallets if applicable.	52.6
	Transfer funds to a new wallet.	36.8
	Lock your account.	68.4
	Enable listing to a safe address.	13.2
	Other: None	15.8

	Other: Some of these seem like something I'd do because it's not that different from having another type of account with money hacked.	2.6
It's safe to use SMS/Email authentication for your NFT account.	Agree.	34.2
	Disagree.	15.8
	Not sure.	50

Table 4: Security Best Practices Checklist Result

Task	Best Practice	Number of participants
Download and Installation	Download from the official site.	5
	Check site validity.	2
	Using the wallet as the only tab in their browser.	5
	If there is no dedicated crypto wallet browser, don't use social media or Google accounts on the browser alongside the wallet.	5
	Use a VPN to encrypt and anonymize traffic (especially in public wifi).	0
Create an account	Generate complex and unique passwords.	3
	Avoid storing passwords in an online password manager.	1
Verification	Split the seed phrase.	0
	Stored seed phrase in an encrypted hard drive/storage medium (keep it offline).	3
	Make more than one copy.	0
Secure	Adjust spending limits/token allowance.	0
	Set Auto-Lock Timer to <5 minutes.	0
	Turn off any experimental features.	0
	Turn on Show incoming transaction.	3
	Turn on Use Phishing Detection.	5
	Turn off Participate in MetaMetrics.	0
	Turn on all alerts.	0
Connect to NFT marketplace	Clear privacy data, browser history, and cookies at regular intervals.	0
	Research the token background/history (Google search, third-party analysis tool, etc.).	1
	Lock/log out of their wallet after using it.	0
	Always disconnect their crypto wallet from dApps when you are done.	2

Table 5: Improvements in the High-Fidelity Prototype Design

Improvement	Page	Detail
Restrictions	Sign-up	Password strength (length and combination)
	Security & Privacy	Necessary security measures are on by default, and users cannot disable them (Beginner Mode).
	Advanced Alerts	
	Home	Mandatory system walkthrough to understand important processes.
Pop-up Guidance	Sign-up	Security tips (password management).
	Secret Recovery Phrase	Explain the secret recovery phrase. Tips on how to securely store the phrase.
	Settings	Show options users should pay attention to.
	Security & Privacy	Explain each feature functionality and its importance.
	Advanced Alerts	
	Connect to Testnet	Explain the testnet and how to connect to it
Reminder	Security & Privacy	Added security reminder options (Check App/Project Background, Disconnect App, Lock Account)

B PROTOTYPE

- Paper Prototype
- Low Fidelity Wireframe
- High Fidelity Prototype